تحليل الفجوات وقائمة التطوير — منصة GRC لمصرف ليبيا الإسلامي

> أُعدّ بعد مراجعة عروض: Ocean/ITS، OneSumX (AFS)، Shamil (Digitinary)، SHIRA (GoGlobal)، Rabbit-Hole، FOCUS GRC، وملف مقارنة اللجنة، ومقارنتها بالمنصة الحالية. التفاصيل القابلة للفرز في `docs/LIB_GRC_Gap_Backlog.xlsx`.

تحفظات يجب قراءتها أولاً

- تقييم الموردين **كما ورد في عروضهم** دون تحقق مستقل أو عرض تجريبي؛ والتقييم الذاتي لمنصتنا ليس تقييماً مستقلاً.
- لم أستطع فتح موقع مصرف ليبيا المركزي (محجوب)؛ ما يخص مدونة الحوكمة (2010) ودليل الحوكمة (التعميم 19/2024) من ملخص بحث ويجب التحقق من النص الرسمي. كذلك تاريخ سريان لائحة المخاطر التشغيلية الإماراتية يحتاج التحقق.
- متطلبات بازل SMA وBCBS 239 وISO وCOSO ذُكرت من معرفتي العامة ولم أراجع نصوصها هنا.
- تقديرات الجهد أولية (±50%) بأيام عمل مطوّر واحد، دون إدارة المشروع واختبارات القبول.
- ملف Excel لم يُعاد حسابه داخل بيئتي (LibreOffice لا يفتح الملفات هنا)؛ الصيغ بسيطة (COUNTIF/SUM) وتُحسب عند فتحه في Excel. تحققت من أرقام الملخص في بايثون وهي المذكورة أدناه.

الخلاصة

- **46 قدرة** قورنت: منفّذة بالكامل لدينا **10**، جزئية **10**، غير موجودة **26**.
- في سيناريو POC (17 خطوة): مغطاة كلياً **8**، جزئياً **5**، مفقودة **4** (اختبار الضوابط، التصعيد الآلي، API، AD/SSO).
- أكبر الفجوات: **مكتبة الضوابط واختبارها، محرك الموافقات (Maker/Checker)، الإشعارات والتصعيد بالبريد، استمرارية الأعمال (BIA/BCP)، سجل التعليمات والتعاميم، حوكمة اللجان، التكامل (API/SSO)، التصدير الأصلي XLSX/PDF**.
- **فرصة تميّز**: لم يصف أي عرض وحدة امتثال شرعي (قرارات الهيئة، المراجعة الشرعية، عدم الالتزام، تطهير الدخل). هذا ما يحتاجه مصرف إسلامي فعلاً ويمكننا بناؤه (GRC-020).
- **نقاط قوتنا**: تقييد البيانات بالإدارة/الفرع، سجل تدقيق، رفع أدلة آمن، واجهة عربية RTL حقيقية، قابلية المخاطر والتجاوزات، RCSA، مؤشرات KRI، وكلفة امتلاك منخفضة جداً مقارنة بالعروض.
- **مخاطر الاستضافة**: بنود الاستمرارية والـHA/DR والـSSO/AD والتكامل المصرفي تحتاج بنية أقوى من الاستضافة المشتركة (GRC-039).

ملاحظات على العروض تستحق المتابعة قبل الترسية

- **Rabbit-Hole:** يذكر المقترح (ص16) أن وحدة BCM «قيد البناء»، بينما تصنّف مقارنة اللجنة BCM لديه «قوي». يلزم تثبيت كتابي للجاهزية قبل الترسية.
- **Rabbit-Hole:** مخطط البنية وقاموس البيانات ملكية فكرية لدى المورد (ص20)، والتكامل غير مشمول في السعر، وربط الدفعات 20/30/40/10%. تأكد من الحق في تصدير البيانات عند الخروج.
- **FOCUS:** تعارض في رسوم الصيانة داخل العرض (15,000 مقابل 12,600) كما أشارت اللجنة؛ ومتطلبات خوادم Windows/IIS/.NET و MS SQL و16GB/1TB على عاتق المصرف.
- **SHIRA:** قسم كبير استشاري؛ الترخيص «دائم/لمدة التعاقد» (ص24) يحتاج توضيحاً؛ ربط KRI/KPI الآلي يحتاج جهداً برمجياً يُقدَّر لاحقاً (ص28). ورقة العرض تمنع إطلاع طرف ثالث دون موافقة كتابية.
- **Shamil:** منصة تطوير مخصصة (Spring Boot/React/Keycloak/Camunda) وليست منتجاً جاهزاً: النتيجة «بناء مخصص» بسقف 5–6 أشهر وملكية مشتركة للشيفرة؛ مواصفاته الوظيفية الأغنى (RCSA/خسائر/KRI/BCM/ESG) هي الأفضل مرجعاً لمتطلباتنا.
- **OneSumX:** 5 مستخدمين مسمّين فقط، زيادة سنوية CPI+1% لعقد 5 سنوات، والسفر والضرائب خارج السعر؛ تفاصيل KRI «أقل بروزاً» في العرض نفسه.
- **Ocean/ITS:** عرض استشاري بلا منصة (200 ألف دولار) وتاريخه 31/08/2025 وصلاحيته 30 يوماً، أي أنه منتهي الصلاحية ما لم يُجدَّد؛ مناسب لمسار IT/Cyber GRC منفصل.
- **عام:** لم يصف أي من العروض وحدة امتثال شرعي (قرارات/تدقيق/عدم التزام/تطهير)؛ هذا متطلب فريد للمصرف الإسلامي يمكن أن تتميز به منصتنا.

الممارسات الدولية والإقليمية وما تعنيه لنا

الممارسة	المضمون	ما يعنيه لمنصتنا	بنود
اتفاقية بازل: المبادئ المنقّحة لإدارة المخاطر التشغيلية (2021)	12 مبدأً: الحوكمة، بيئة إدارة المخاطر (تحديد وتقييم، إدارة التغيير، المتابعة والإبلاغ، الرقابة والتخفيف)، تقنية المعلومات، استمرارية الأعمال، الإفصاح.	الضوابط واختبارها، إدارة التغيير (محفّزات التقييم)، ICT، BCP	GRC-001/002/012/015/016
بازل: مبادئ المرونة التشغيلية (2021)	قدرة المصرف على الصمود والتكيف والتعافي: الخدمات الحرجة، خرائط الاعتماديات، حدود تحمل الانقطاع، اختبار السيناريوهات، الأطراف الثالثة.	وحدة BIA/BCP كاملة وحدود التحمل والأطراف الثالثة	GRC-015/016/017/029
IFSB-1: إدارة المخاطر للمؤسسات المقدِّمة للخدمات المالية الإسلامية	مخاطر خاصة: عدم الالتزام الشرعي، مخاطر معدل العائد، الاستثمار بالمشاركة، التجارة المنقولة، ومخاطر تشغيلية.	لدينا الفئات؛ ينقص تقييم ومؤشرات متخصصة	GRC-020/021
IFSB-10 ومعايير AAOIFI للحوكمة: الحوكمة الشرعية	هيئة رقابة شرعية، مراجعة/تدقيق شرعي داخلي، تقرير الالتزام الشرعي.	وحدة الامتثال الشرعي (فجوة لا يغطيها أي عرض)	GRC-020
IFSB-15 (كفاية رأس المال) وIFSB-30 (الحوكمة المؤسسية)	معايير احترازية مشتقة من بازل للمصارف الإسلامية؛ IFSB-30 مبادئ حوكمة منقحة.	حوكمة المجلس واللجان؛ رأس المال خارج النطاق	GRC-022/035

الممارسة	المضمون	ما يعنيه لمنصتنا	بنود
ساما (السعودية): إطار الحوكمة الشرعية وإدارة المخاطر للمصرفية المتوافقة مع الشريعة	توقعات رقابية على وظيفة الامتثال الشرعي وإدارة مخاطر الائتمان والسوق والتشغيل والسيولة والاستثمار بالأسهم.	مثال إقليمي لوحدة شرعية مدمجة بإدارة المخاطر	GRC-020/021
مصرف الإمارات المركزي: لائحة المخاطر التشغيلية	تربط المخاطر التشغيلية والمرونة بالحوكمة والضوابط والتقنية وإدارة التغيير والأطراف الثالثة (تاريخ السريان المذكور في نتيجة البحث: 14 سبتمبر 2026؛ يلزم التحقق من النص الرسمي).	دمج التشغيلي والمرونة والأطراف الثالثة	GRC-015/029
مصرف ليبيا المركزي: مدونة الحوكمة للقطاع المصرفي (2010) ودليل الحوكمة (التعميم 19 لسنة 2024)	لجان المجلس (التدقيق، المكافآت، المخاطر، الحوكمة) ومبادئ إدارة مخاطر الائتمان والسوق والتشغيل والسيولة والسلوك. لم أستطع فتح صفحة المصرف المركزي (محجوبة)؛ المعلومة من ملخص بحث ويجب التحقق من التعميم الأصلي.	حوكمة اللجان والتزام التشكيل والاجتماعات	GRC-022
ISO 31000 / COSO ERM	ربط المخاطر بالاستراتيجية والأداء وقابلية تحمل المخاطر.	أهداف استراتيجية وقابلية المخاطر والقبول بصلاحيات	GRC-011/022
BCBS 239 (تجميع بيانات المخاطر والإبلاغ)	جودة البيانات، الاكتمال، التوقيت، الأصل البياني للإبلاغ.	بوابة جودة بيانات KRI، نموذج بيانات موحد	GRC-008/024
سوق منصات GRC/IRM	المنصات الكبرى تركّز على تنسيق سير العمل عبر المخاطر والامتثال والأطراف الثالثة والمرونة؛ وغارتنر لم تعد تعتبر IRM سوقاً مستقلاً بل GRC.	محرك سير عمل ووحدات مترابطة بنموذج بيانات واحد	GRC-004/005

مصفوفة القدرات (2 = مغطى، 1 = جزئي، 0 = غير موجود)

القدرة	منصتنا	FOCUS GRC	Rabbit-Hole	SHIRA	Shamil	OneSumX	Ocean/ITS
سجل المخاطر (أسباب، عواقب، مالك، تواريخ)	2	2	2	2	2	2	0
مصفوفة تقييم قابلة للتهيئة (أصلي/متبقٍ)	2	2	2	2	2	2	1
مكتبة ضوابط مركزية وربط خطر ↔ ضابط (متعدد لمتعدد)	1	2	1	2	2	2	0
تصنيف الضوابط (وقائي/كشفي/تصحيحي، رئيسي/ثانوي، آلي/يدوي، دوري)	0	0	1	2	2	2	0
اختبار الضوابط (تصميم/تشغيل، قوائم تحقق، عينات، جدولة، أدلة)	0	2	1	2	2	2	0
حساب الخطر المتبقي المستند إلى نتائج اختبار الضوابط	0	1	1	2	2	2	0
RCSA: استبيانات ومراجعة واعتماد	2	2	2	2	2	2	1
جدولة دورات RCSA وإعادة التقييم المحفّز بالأحداث	0	1	2	2	2	1	0

القدرة	منصتنا	FOCUS GRC	Rabbit-Hole	SHIRA	Shamil	OneSumX	Ocean/ITS
خطط المعالجة (مسؤول، موعد، حالة)	2	2	2	2	2	2	2
قبول الخطر بصلاحيات مرتبطة بالقابلية للمخاطر	1	1	1	2	2	1	1
بيانات قابلية تحمل المخاطر ومتابعة التجاوزات	2	1	2	2	2	1	1
تسجيل الحوادث وشبه الحوادث (إجمالي/مستردات/صافي)	2	2	2	2	2	2	1
تصنيف أحداث Basel وخطوط الأعمال	0	1	1	1	2	2	0
المستردات حسب المصدر، الأثر غير المالي، التسوية مع الأستاذ العام، عتبات التصعيد	0	1	1	1	2	2	0
ربط الحدث بإعادة تقييم الخطر وكشف التكرار/الأنماط	1	2	1	2	2	2	0
KRIs: حدود، دورية، تنبيهات على الشاشة	2	2	2	2	2	2	1
KRIs متقدمة: 4 مستويات، تغذية آلية، بوابة جودة بيانات، مؤشرات مركبة، سجل خرق	0	1	1	1	2	1	0
تحليل الأثر على الأعمال وأهداف التعافي (RTO/RPO/MTPD)	0	2	1	2	2	0	2
خطط الاستمرارية، الاختبارات والتمارين، سجل الأزمة، شجرة الاتصال، الإشعار الطارئ	0	2	1	1	2	0	2
سجل التعليمات والتعاميم الرقابية وتوزيعها والمراسلات	1	2	2	2	0	1	1
فحوصات الامتثال الدورية ومؤشرات الامتثال	0	2	2	2	0	1	1
دورة حياة الوثائق والسياسات (اعتماد، إقرار الاطلاع)	1	2	2	2	0	0	1
حوكمة المجلس واللجان: التشكيل، الاجتماعات، المحاضر، الحضور، التقييم، فحص الالتزام بتعليمات المصرف المركزي	1	2	0	2	0	1	1
الأهداف الاستراتيجية وبطاقات الأداء المتوازن ومؤشرات الأداء	0	0	0	2	0	0	0
هيكل تنظيمي متعدد المستويات وخطوط الدفاع الثلاثة	1	2	1	2	2	2	1
مكتبة العمليات والمنتجات والخدمات والأصول وربطها بالمخاطر	0	1	1	2	2	2	2
التدقيق الداخلي المبني على المخاطر	0	2	1	1	0	0	0
مخاطر الأطراف الثالثة والتعهيد	0	0	0	1	1	0	2
مخاطر تقنية المعلومات والأمن السيبراني (ISO 27001/27005، تصنيف الأصول)	0	1	0	1	0	0	2
المخاطر البيئية والاجتماعية والحوكمة (ESG)	0	0	0	2	2	0	0
اختبارات الضغط وكفاية رأس المال (ICAAP)	0	0	0	1	0	0	0

القدرة	منصتنا	FOCUS GRC	Rabbit-Hole	SHIRA	Shamil	OneSumX	Ocean/ITS
فئات مخاطر إسلامية قابلة للتهيئة	2	0	0	1	0	0	0
وحدة امتثال شرعي (سجل قرارات/فتاوى، مراجعة شرعية، أحداث عدم التزام، تطهير الدخل المحرّم)	1	0	0	0	0	0	0
واجهة عربية/إنجليزية RTL/LTR	2	2	2	2	1	1	0
التقويم الهجري	0	0	2	0	0	0	0
الرقابة الثنائية (Maker/Checker) على السجلات	1	2	2	1	2	2	0
محرك سير عمل قابل للتهيئة وفصل المهام	0	2	2	1	2	2	0
تنبيهات بريد/رسائل نصية وتصعيد تلقائي	0	2	2	2	2	1	0
إدارة المهام والتقويم وصفحة «مهامي»	0	1	1	2	1	1	0
لوحات وتقارير: مصمم تقارير، جدولة، تصدير PDF/Excel	1	2	2	2	2	2	1
الدخول الموحد/Active Directory/LDAP وMFA	0	2	2	1	2	1	0
صلاحيات حسب الدور ونطاق (إدارة/فرع) وسجل تدقيق	2	2	2	2	2	2	1
واجهات API وربط مع النظام المصرفي	0	2	2	1	2	1	1
توفر عالٍ (HA) واسترداد الكوارث	0	1	2	1	2	1	0
ذكاء اصطناعي وتحليلات متقدمة	0	0	0	1	2	0	1
محتوى تنظيمي ليبي جاهز	0	1	2	2	1	0	1

اختبار سيناريو POC (ذاتي)

الخطوة	الحالة	ملاحظة
حدث خسارة	كامل	تسجيل كامل بالإجمالي والمستردات والصافي
السبب الجذري	جزئي	حقل نصي إلزامي للإغلاق؛ بلا تصنيف أسباب
RCSA	جزئي	استبيان ومراجعة؛ بلا جدولة ولا ضوابط داخل التقييم
اختبار الضوابط	مفقود	غير موجود

الخطوة	الحالة	ملاحظة
الخطر المتبقي	كامل	صريح مع مبررات وفئات
خطة المعالجة	كامل	مع مسؤول وموعد وحالة وتأخر
خرق KRI	جزئي	حالة وتنبيه على الشاشة؛ بلا سجل خرق ولا بريد
التصعيد	مفقود	لا تصعيد آلي
لوحة المجلس	كامل	خرائط حرارة ومؤشرات؛ بلا حزمة PDF للمجلس
واجهة عربية	كامل	
AD/SSO	مفقود	غير موجود
Maker/Checker	جزئي	RCSA فقط
رفع الأدلة	كامل	مع فحص المحتوى وحفظ خارج الجذر العام
سجل التدقيق	كامل	
استدعاء API	مفقود	غير موجود
تصدير PDF/Excel	جزئي	CSV وطباعة PDF من المتصفح؛ لا XLSX/PDF أصلي
دور ضابط ارتباط الفرع	كامل	مع تقييد البيانات بالفرع

قائمة التطوير المقترحة

الإصدار 1: أساس الضوابط وسير العمل — 197 يوم عمل تقريباً

المعرف	البند	الأولوية	أيام	يعتمد على	الاستضافة	معيار القبول
GRC-001	**مكتبة ضوابط مركزية**: كيان ضابط مستقل (رمز، وصف، تصنيف، مالك، تكرار، آلي/يدوي، رئيسي/ثانوي) وربط متعدد لمتعدد مع المخاطر.	P0	15	-	ok	إنشاء ضابط وربطه بعدة مخاطر وبالعكس؛ تصفية بالتصنيف؛ يظهر في صفحة الخطر وسجل التغييرات.
GRC-002	**اختبار الضوابط وبرامج الفحص**: برامج اختبار (تصميم/تشغيل)، قوائم تحقق، عينات، جدولة، مختبِر مستقل عن مالك الضابط، دليل إلزامي لتقييم «فعّال».	P0	25	GRC-001	cron	لا يمكن تقييم ضابط فعّالاً بلا دليل؛ فجوة الضابط تنشئ إجراءً؛ سجل نتائج بالتاريخ.

المعرف	البند	الأولوية	أيام	يعتمد على	الاستضافة	معيار القبول
GRC-003	**الخطر المتبقي المقترح من نتائج الاختبار**: عرض قيمة متبقية مقترحة مشتقة من فعالية الضوابط بجانب التقييم الصريح مع تنبيه عند التعارض (دون خصم تلقائي).	P1	8	GRC-002	ok	تظهر المقارنة (صريح/مقترح) وتُطلب مبررات عند الفرق الكبير.
GRC-004	**محرك موافقات (Maker/Checker) على السجلات**: مسار إعداد ← مراجعة ← اعتماد قابل للتهيئة لكل نوع سجل (خطر، حادث، التزام، سياسة، مؤشر)، مع منع نفس المستخدم من الإعداد والاعتماد.	P0	25	-	ok	تفعيل المسار لنوع سجل واحد على الأقل دون تعديل كود؛ لا يُغلق سجل قبل الاعتماد؛ مسجّل في التدقيق.
GRC-005	**الإشعارات بالبريد والتصعيد التلقائي**: إعداد SMTP، قوالب ثنائية اللغة، تذكير بالمواعيد، تصعيد المتأخر حسب مصفوفة، يعمل بمهمة cron واحدة في cPanel.	P0	15	-	smtp	إرسال تذكير قبل الموعد وتصعيد بعده؛ سجل إرسال؛ إيقاف/تفعيل لكل مستخدم.
GRC-006	**صفحة «مهامي» والتقويم**: قائمة موحدة لما يخص المستخدم: إجراءات، مراجعات، قراءات KRI، اختبارات ضوابط، التزامات، تقييمات ذاتية، مع عرض تقويم.	P1	10	-	ok	تعرض كل المهام المفتوحة للمستخدم مرتبة بالموعد ومع روابط مباشرة.
GRC-007	**تصدير XLSX وPDF أصلي وحزمة تقرير المجلس**: تصدير Excel حقيقي وPDF للتقارير وحزمة دورية (لوحة، أعلى المخاطر، الخسائر، KRIs، المتأخرات) بالعربية RTL.	P0	12	-	ok	ملف PDF عربي سليم؛ XLSX يحافظ على العربية والأرقام؛ بنفس صلاحيات الشاشة.
GRC-008	**KRIs متقدمة**: 4 مستويات حدود، مصدر بيانات (يدوي/استيراد/API)، بوابة جودة بيانات، علامة «متأخر»، سجل خرق مع مبررات وتصعيد، مؤشرات مركبة، مراجعة دورية للمؤشر.	P1	20	GRC-004,GRC-005	cron	خرق حرج يفتح سجل خرق ويُصعَّد؛ لا يُنشر مؤشر قبل التحقق؛ مؤشر مركب بمعادلة معتمدة.
GRC-009	**تصنيف Basel وخطوط الأعمال والمستردات حسب المصدر**: تصنيف أحداث Basel، خط عمل، منتج، نظام، مصادر استرداد (تأمين/عميل/موظف/مورد)، الأثر غير المالي، أنواع الحدث (فعلي، شبه، ربح، محتمل، مسترد كلياً).	P1	15	-	ok	حقول إلزامية قابلة للتهيئة؛ تقرير خسائر حسب نوع Basel وخط العمل.
GRC-010	**عتبات التسجيل والتصعيد وبوابات الإغلاق وكشف التكرار**: عتبات مالية للتصعيد، بوابة إغلاق (سبب جذري، قيمة مؤكدة، إجراءات معتمدة)، اقتراح تجميع الأحداث المتشابهة، وإطلاق إعادة تقييم الخطر.	P1	12	GRC-004,GRC-005	ok	حادث فوق العتبة يُصعَّد تلقائياً؛ لا إغلاق دون استيفاء البوابة؛ اقتراح أنماط بقاعدة بسيطة.
GRC-011	**مصفوفة صلاحيات قبول الخطر وفحص اتساق الحدود**: قبول الخطر المتبقي المتجاوز للحد يتطلب مستوى صلاحية محدداً؛ فحص اتساق حدود KRI مع القابلية.	P1	10	GRC-004	ok	قبول بدون الصلاحية مرفوض؛ تقرير بالمخاطر المقبولة وصلاحياتها.
GRC-012	**دورات RCSA مجدولة وإعادة التقييم المحفّز**: جدولة سنوية/حسب الأهمية وإطلاق تلقائي، ومحفّزات (حادث جسيم، فشل ضابط رئيسي، منتج جديد، تغيير نظام/لائحة).	P1	12	GRC-005	cron	تُطلق تقييمات الدورة تلقائياً؛ حادث جسيم يقترح إعادة تقييم للخطر المرتبط.
GRC-013	**التحقق الثنائي (MFA) وإعادة تعيين كلمة المرور بالبريد**: TOTP لمن يختاره المدير أو إلزامياً لأدوار محددة، رموز استرداد، إعادة تعيين كلمة مرور آمنة بالبريد.	P1	8	GRC-005	smtp	حساب بـ MFA لا يدخل بدون رمز؛ إعادة التعيين برابط لمرة واحدة ينتهي سريعاً.
GRC-014	**استيراد جماعي (CSV/XLSX) مع التحقق**: استيراد المخاطر والضوابط والمؤشرات وقراءاتها والتزامات الامتثال بقوالب، معاينة وأخطاء قبل الحفظ، وتسجيل في التدقيق.	P1	10	-	ok	استيراد 500 صف مع تقرير أخطاء؛ لا حفظ جزئي؛ قابل للتراجع.

الإصدار 2: الاستمرارية والامتثال والشرعية والحوكمة — 228 يوم عمل تقريباً

المعرف	البند	الأولوية	أيام	يعتمد على	الاستضافة	معيار القبول
GRC-015	**تحليل الأثر على الأعمال وأهداف التعافي**: عمليات حرجة، أثر مالي/تشغيلي/قانوني/سمعة، MTPD/RTO/RPO مع فحص اتساق، المصادر والاعتماديات والمورّدين.	P0	20	GRC-001	ok	لا اعتماد لخطة إذا RTO أقصر من قدرة النظام الداعم؛ تقرير BIA لكل إدارة.
GRC-016	**خطط الاستمرارية والاختبارات وسجل الأزمة**: خطط لكل إدارة، فرق الاستجابة وشجرة الاتصال، سيناريوهات اختبار ونتائج وإجراء تصحيحي إلزامي عند الفشل، سجل أزمة زمني، مراجعة بعد الحدث.	P1	25	GRC-015,GRC-004	ok	اختبار فاشل يفتح إجراءً وموعد إعادة اختبار؛ سجل أزمة بتسلسل زمني.
GRC-017	**الإشعار الطارئ (بريد/SMS) وحدود تحمل الانقطاع**: قوائم نداء، قوالب رسائل، مزود SMS عبر API، تأكيد الاستلام، وتعريف حدود تحمل الانقطاع للخدمات الحرجة.	P2	12	GRC-005	infra	إرسال تجريبي إلى مجموعة مع تأكيد استلام؛ سجل بالنتائج.
GRC-018	**سجل التعليمات والتعاميم الرقابية والمراسلات**: تعليمات على مستوى المادة، تعاميم واردة، توزيع وتأكيد استلام، مراسلات مع المصرف المركزي، ربط بالمخاطر والضوابط والسياسات.	P1	18	GRC-001	ok	تعميم جديد يُوزَّع على إدارات مع تتبع الاستلام والإجراء.
GRC-019	**فحوصات الامتثال الدورية ومؤشرات الامتثال**: قوائم تحقق دورية بمسؤول وموعد، نتائج وأدلة، مؤشرات امتثال وتقرير امتثال.	P1	15	GRC-018,GRC-005	cron	فحص مجدول يتحول إلى مهمة؛ تقرير نسبة الامتثال حسب الإدارة.
GRC-020	**وحدة الامتثال الشرعي**: سجل قرارات/فتاوى هيئة الرقابة الشرعية وربطها بالمنتجات والعقود، المراجعة/التدقيق الشرعي وملاحظاتها، أحداث عدم الالتزام الشرعي وتتبعها، تحويل الدخل المحرّم وتطهيره، تقرير سنوي للالتزام الشرعي.	P0	30	GRC-004	ok	حدث عدم التزام شرعي يُصعَّد لهيئة الرقابة الشرعية ويُقفل بقرارها؛ تقرير سنوي من البيانات.
GRC-021	**تقييم مخاطر خاصة بالصيرفة الإسلامية**: نماذج تقييم لمخاطر التجارة المنقولة ومعدل العائد والاستثمار بالمشاركة والأصول المؤجّرة، وربط بحسابات الاستثمار، ومؤشرات KRI شرعية.	P2	15	GRC-001	ok	قالب تقييم لكل نوع خطر إسلامي مع مؤشرات افتراضية قابلة للتعديل.
GRC-022	**حوكمة المجلس واللجان: التشكيل والاجتماعات والمحاضر**: تشكيل المجلس واللجان وأعضاؤها، جدولة الاجتماعات، جدول أعمال، محاضر، حضور، تقييم أداء، وفحص الالتزام بتعليمات المصرف المركزي (التشكيل، عدد الجلسات).	P1	25	GRC-004	ok	اجتماع يولّد مهام من القرارات؛ تقرير التزام بعدد الجلسات والحضور.
GRC-023	**هيكل تنظيمي متعدد المستويات وخطوط الدفاع**: شجرة تنظيمية بعدد مستويات مرن، مالكو أدوار، نطاق صلاحيات حسب الشجرة، تجميع المخاطر صعوداً.	P1	15	-	ok	تجميع نتائج الإدارة الفرعية في الأعلى؛ صلاحية على فرع الشجرة.
GRC-024	**مكتبات العمليات والمنتجات والخدمات والأصول**: عمليات بمالك، منتجات وخدمات حرجة، أصول، ربطها بالمخاطر والحوادث وBIA؛ منع خطر بلا مرجع مؤسسي.	P1	15	GRC-023	ok	لا يُنشأ RCSA إلا على عملية معتمدة؛ تقرير المخاطر حسب العملية.
GRC-025	**مسار اعتماد السياسات وإقرار الاطلاع**: مسار مسودة ← مراجعة ← اعتماد ← نشر، إقرار الموظفين بالاطلاع، تذكير بالمراجعة الدورية.	P2	12	GRC-004,GRC-005	ok	سياسة معتمدة تُنشر وتطلب إقرار فئات محددة وتتابع نسب الإقرار.
GRC-026	**مصمم تقارير وجدولة وإرسالها**: اختيار الحقول والتصفية والتجميع، حفظ القالب، جدولة وإرسال بالبريد بصيغة PDF/XLSX.	P2	20	GRC-005,GRC-007	cron	تقرير محفوظ يُرسل أسبوعياً لقائمة مستلمين بصلاحياتهم.

المعرف	البند	الأولوية	أيام	يعتمد على	الاستضافة	معيار القبول
GRC-027	**التقويم الهجري**: إدخال وعرض التواريخ بالتقويم الهجري والميلادي حسب تفضيل المستخدم.	P2	6	-	ok	تحويل صحيح وعرض مزدوج في النماذج والتقارير.

الإصدار 3: التدقيق والتكامل — 140 يوم عمل تقريباً

المعرف	البند	الأولوية	أيام	يعتمد على	الاستضافة	معيار القبول
GRC-028	**التدقيق الداخلي المبني على المخاطر (مبسّط)**: عالم التدقيق، خطة سنوية من تقييم المخاطر، أوراق عمل بقوائم تحقق، ملاحظات وتوصيات تتحول إلى إجراءات وتتبع.	P2	35	GRC-001,GRC-004	ok	ملاحظة تدقيق تنتج إجراءً بمسؤول وموعد وتظهر للإدارة المعنية.
GRC-029	**مخاطر الأطراف الثالثة والتعهيد**: سجل موردين، تصنيف الحرجية، استبيانات العناية الواجبة، عقود ومؤشرات أداء ومخاطر، خطط خروج.	P2	20	GRC-001	ok	تقييم مورد حرج يُكرر سنوياً ويرتبط بـBIA.
GRC-030	**مخاطر تقنية المعلومات والأمن السيبراني**: سجل أصول معلوماتية وتصنيف، ربط الضوابط بـISO 27001/NIST (بيان التطبيق SoA)، ثغرات، حوادث أمنية.	P2	25	GRC-001	ok	مصفوفة ضوابط ISO مرتبطة بمخاطر وأصول مع تقرير فجوات.
GRC-031	**واجهة REST وصلاحيات الرموز و Webhooks**: واجهات قراءة/كتابة موثقة (OpenAPI) برموز بنطاق محدد، حدود معدل، سجل تدقيق، لاستيراد الخسائر وقراءات KRI.	P1	20	-	ok	عميل خارجي يرسل قراءة KRI ويقرأ المخاطر ضمن نطاق رمزه؛ كل نداء مسجل.
GRC-032	**الدخول الموحد (OIDC/SAML) وLDAP/AD**: ربط مع موفر هوية المصرف؛ مزامنة المجموعات مع الأدوار والنطاق.	P1	15	-	infra	دخول مستخدم من AD يُعيَّن للدور الصحيح؛ تعطيله في AD يمنع الدخول. يتطلب مسار شبكة إلى AD (غير متاح عادةً على استضافة مشتركة).
GRC-033	**ربط النظام المصرفي والأستاذ العام (تسوية الخسائر)**: استيراد قيود أو تقارير للتسوية مع الخسائر المسجلة وقراءات KRI آلية.	P2	25	GRC-031	infra	تقرير فروقات بين الخسائر والقيود؛ يعتمد على واجهات النظام المصرفي.

الإصدار 4: متقدم — 125 يوم عمل تقريباً

المعرف	البند	الأولوية	أيام	يعتمد على	الاستضافة	معيار القبول
GRC-034	**المخاطر البيئية والاجتماعية والحوكمة (ESG)**: تصنيفات ESG وربطها بالعمليات والمخاطر والأحداث والمؤشرات.	P3	20	GRC-024	ok	تقييم ESG مرتبط بخطر تشغيلي دون ازدواج.
GRC-035	**اختبارات الضغط وتحليل السيناريو**: سيناريوهات خسائر تشغيلية ومؤشرات ضغط (لا يشمل حساب رأس المال).	P3	25	GRC-009	ok	سيناريو بمعاملات يُنتج أثراً مقدراً وتقريراً.
GRC-036	**تحليلات الأنماط وتنبؤ خرق KRI**: كشف الأنماط الإحصائي وتنبؤ بسيط بالاتجاه وتنبيه قبل الخرق (بدون LLM).	P3	20	GRC-008,GRC-010	ok	قائمة أنماط مقترحة تُراجع يدوياً؛ تنبيه استباقي بمنهجية موثقة.

المعرف	البند	الأولوية	أيام	يعتمد على	الاستضافة	معيار القبول
GRC-037	**مساعد ذكاء اصطناعي (اختياري)**: أسئلة طبيعية على البيانات، واقتراح مخاطر/ضوابط. يتطلب بنية خاصة وسياسة خصوصية بيانات.	P3	40	GRC-031	infra	يُنفَّذ فقط بعد موافقة أمن المعلومات وبيئة محلية.
GRC-038	**رأس المال التشغيلي وبيانات الخسائر التاريخية (إن لزم)**: تجميع مؤشر الأعمال وسجل خسائر 10 سنوات وفق عتبات إن طلبها المصرف المركزي.	P3	20	GRC-009	ok	يُبنى فقط عند ثبوت المتطلب الرقابي.

متطلبات غير وظيفية — 53 يوم عمل تقريباً

المعرف	البند	الأولوية	أيام	يعتمد على	الاستضافة	معيار القبول
GRC-039	**بنية إنتاج للمصرف: خادم خاص/محلي، HA/DR، نسخ احتياطي مؤتمت**: الاستضافة المشتركة مناسبة للتجربة؛ للإنتاج المصرفي تُقيَّم بيئة يتحكم بها المصرف، مع نسخ احتياطي واسترداد مجرّب (RTO/RPO).	P0	15	-	infra	وثيقة قرار بنية معتمدة من أمن المعلومات + تمرين استرداد ناجح.
GRC-040	**اختبار اختراق وتقييم ثغرات مستقل**: اختبار خارجي قبل الإنتاج وإصلاح الملاحظات.	P0	10	-	ok	تقرير بلا ملاحظات حرجة/عالية مفتوحة.
GRC-041	**حماية سجل التدقيق من التعديل (سلسلة تجزئة) وسياسة الاحتفاظ**: ربط كل سجل بتجزئة السابق، وسياسة احتفاظ وأرشفة.	P2	8	-	ok	كشف أي تعديل في السجل بفحص دوري.
GRC-042	**اختبارات آلية لكل وحدة جديدة ومراجعة إمكانية الوصول**: توسيع الاختبارات الحالية (609) لكل وحدة؛ مراجعة WCAG وقارئات الشاشة.	P1	15	-	ok	تغطية اختبارية لكل ميزة؛ تقرير وصول.
GRC-043	**مراجعة لغوية متخصصة للواجهة العربية**: مراجعة المصطلحات المصرفية/الشرعية من متخصص قبل الإنتاج.	P1	5	-	ok	قاموس مصطلحات معتمد ومطبّق.

الاستضافة: `ok` تعمل على الاستضافة المشتركة، `cron` تحتاج مهمة مجدولة، `smtp` تحتاج بريداً، `infra` تحتاج بنية أو شبكة خارج الاستضافة المشتركة.

ترتيب التنفيذ المقترح

1. GRC-001/002/004/005 أولاً: هي الأساس الذي تقوم عليه بقية البنود (الضوابط، سير الموافقات، الإشعارات).
2. GRC-007 (تصدير حقيقي) وGRC-020 (الامتثال الشرعي) لأنهما الأعلى قيمة ظاهرة للجنة.
3. GRC-015 (BIA) ثم بقية الاستمرارية والامتثال.
4. GRC-039/040 (بنية الإنتاج واختبار الاختراق) شرط قبل أي تشغيل فعلي ببيانات حقيقية.

5. قرار اللجنة: هل المنصة الحالية مسار بناء داخلي أم مرجع متطلبات فقط؟ الجواب يغيّر أولوية الإصدارين 3 و4.

المصادر

- العروض الفنية والمالية الستة وملف جو جلوبال ولوحة مقارنة اللجنة — مرفوعة من المستخدم — تُقرأ كما وردت دون تحقق مستقل من ادعاءات الموردين
- BIS: Revisions to PSMOR (2021) — https://www.bis.org/bcbs/publ/d515.htm
- BIS: Principles for Operational Resilience (2021) — https://www.bis.org/bcbs/publ/d516.pdf
- /IFSB standards overview — https://islamic-banking.com/ifsb-standards
- SAMA Shariah Governance Framework — https://rulebook.sama.gov.sa/en/shariah-governance-framework-local-banks-operating-saudi-arabia
- SAMA Risk Management for Shariah Compliant Banking — https://rulebook.sama.gov.sa/en/entiresection/10190
- /CBUAE operational risk (via GRC2020 article) — https://grc2020.com/2026/09/27/the-uaes-grc-market-ambition-meets-the-resilience-test
- /Central Bank of Libya — Banking Supervision / governance manual — https://cbl.gov.ly/en/banking-supervision (الصفحة محجوبة من بيئتي؛ المعلومة من ملخص بحث)
- GRC/IRM market overview (MarketsandMarkets) — https://www.marketsandmarkets.com/ResearchInsight/enterprise-governance-risk-compliance-market.asp